

Anexo de Seguridad y Tratamiento de Datos con el Proveedor de Servicios Gestionados (MSP)

RGPD Art. 28 · ISO/IEC 27001:2022 — Anexo A 5.21, 5.22, 5.23, 7.10, 7.14, 8.2, 8.9, 8.15, 8.17, 8.22

Código de documento	SGSI-ACU-004	Versión	0.2
Estado	Revisión documental — pendiente de aprobación	Clasificación	Confidencial
Propietario	Dirección General — Atalaya GP SL		
Autor	El consultor (externo)		
Fecha de emisión	23/08/2026	Fecha de aprobación	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4		
Registro de aprobación	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.		

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	23/08/2026	El consultor (externo)	Emisión inicial. Cierra el contenido pendiente de la deuda de diseño HD-08 (SGSI-REG-006; SGSI-DOC-010 §4.1) y del tratamiento T-10 (SGSI-REG-008): formaliza como encargo del tratamiento (art. 28 RGPD) lo que SGSI-DOC-006 §5 ya exige unilateralmente al MSP. No modifica ni amplía las medidas técnicas de DOC-006 §5; las eleva a obligación contractual bilateral.
0.2	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.

1. Objeto, partes y duración

Este anexo regula, conforme al artículo 28 del RGPD, el tratamiento de datos personales que el Proveedor de Servicios Gestionados (en adelante, «el MSP») realiza por cuenta de Atalaya Gestión Patrimonial SL (en adelante, «el Responsable») en el ejercicio de su administración técnica del correo corporativo (M365), el NAS doméstico y el sistema de CCTV de la residencia y la oficina, conforme al tratamiento T-10 del Registro de Actividades de Tratamiento (SGSI-REG-008).

El MSP actúa en esta relación como Encargado del Tratamiento. Este anexo formaliza contractualmente lo que SGSI-DOC-006 §5 (Política de Gestión de Terceros y del Círculo de Confianza) ya exige al MSP como requisito unilateral de seguridad; no crea medidas técnicas nuevas, las eleva a obligación bilateral exigible y añade las garantías específicas del artículo 28 RGPD que una política interna de seguridad, por sí sola, no puede otorgar.

Duración: ligada a la vigencia del contrato principal de prestación de servicios entre el Responsable y el MSP. La terminación de este anexo, por cualquier causa, no exime al MSP de las obligaciones de confidencialidad y de destino de los datos previstas en la sección 9.

2. Naturaleza, finalidad del tratamiento y colectivos afectados

Naturaleza: administración técnica remota y presencial de los sistemas de información y comunicaciones del Responsable, con acceso administrativo pleno a las plataformas indicadas en la sección 1.

Finalidad: soporte técnico necesario para el funcionamiento de dichos sistemas y, en consecuencia, soporte indirecto de los tratamientos T-01 (videovigilancia) y T-04 (cuaderno de indicios) del Registro de Actividades de Tratamiento (SGSI-REG-008).

Categorías de interesados: todas las personas cuyos datos residen en los sistemas administrados — la familia (incluidos los tres menores), personal doméstico y de plantilla, contratas, visitas, y terceros que aparecen en las comunicaciones corporativas.

Categorías de datos: imagen (CCTV); contenido y metadatos de correo corporativo; documentación familiar, patrimonial y societaria alojada en el NAS. El MSP no está autorizado a acceder al contenido salvo cuando sea estrictamente necesario para la prestación del soporte técnico solicitado, y dicho acceso queda sujeto al registro de sesiones de la sección 4.

3. Instrucciones del Responsable

El MSP trata los datos personales únicamente siguiendo instrucciones documentadas del Responsable, incluida la relativa a las transferencias de datos personales a un tercer país u organización internacional, salvo que esté obligado a ello en virtud del Derecho de la Unión o de los Estados miembros que resulte aplicable al MSP; en tal caso, el MSP informará al Responsable de esa exigencia legal previamente al tratamiento, salvo que el Derecho aplicable lo prohíba por razones importantes de interés público. El canal de instrucciones es el jefe de seguridad, como propietario funcional de la relación técnica con el MSP (SGSI-DOC-003 §6.1).

El MSP informará inmediatamente al Responsable si, en su opinión, una instrucción infringe el RGPD u otras disposiciones de protección de datos.

4. Medidas de seguridad técnicas y organizativas (art. 32 RGPD; Anexo A 5.21, 5.22, 5.23, 7.10, 7.14, 8.2, 8.9, 8.15, 8.17, 8.22)

El MSP implementa y mantiene, sin perjuicio de las que le sean propias por su condición de proveedor de servicios en la nube, las medidas ya exigidas por SGSI-DOC-006 §5 y que este anexo eleva a obligación contractual:

- Cuentas nominales y doble factor: prohibido el uso de credenciales genéricas o compartidas para tareas de administración técnica. Todo acceso administrativo es nominal y exige autenticación multifactor.
- Registro de sesiones: el MSP registra todas las sesiones administrativas sobre los sistemas del Responsable y conserva los registros doce meses, accesibles al jefe de seguridad.
- Sincronización horaria común: todos los sistemas gestionados por el MSP que generan registro (CCTV, NAS, correo, routers) se sincronizan con una referencia horaria única, condición para que la correlación de indicios entre el dominio físico y el digital (SGSI-DOC-009 §5) sea defendible.
- Segmentación de los sistemas de seguridad: se mantiene el diseño de DOC-005 O7 y C-023/C-026, con redes separadas de familia, empleados/invitados y seguridad (CCTV/domótica), acceso administrativo autenticado y cifrado y sin exposición directa de esos sistemas a internet. Cualquier cambio adicional requiere evaluación y aprobación por el proceso de cambios. No se añade segmentación en este anexo.
- Borrado seguro certificado: todo equipo o soporte de almacenamiento retirado del servicio se somete a borrado o destrucción certificada, con acta firmada entregada al jefe de seguridad (Anexo A 7.14, 8.10; SGSI-DOC-002 §5.1).
- Notificación de incidentes de seguridad en menos de 24 horas y prohibición de subcontratar el servicio sin autorización previa y por escrito del Responsable (Anexo A 5.21, cadena de suministro TIC).

5. Personal y confidencialidad

El MSP garantiza que las personas autorizadas para tratar los datos personales se han comprometido a respetar la confidencialidad o están sujetas a una obligación de confidencialidad de naturaleza legal, y que reciben la formación necesaria en materia de protección de datos.

6. Subencargados del tratamiento

El MSP no recurre a otro encargado (subencargado) sin la autorización previa y específica, o general por escrito, del Responsable. En caso de autorización general, el MSP informará al Responsable de cualquier cambio previsto en la incorporación o sustitución de subencargados, dando al Responsable la oportunidad de oponerse. Todo subencargado queda sujeto, mediante contrato, a las mismas obligaciones de protección de datos que las establecidas en este anexo, en particular las de la sección 4.

7. Asistencia al Responsable

El MSP asiste al Responsable, mediante medidas técnicas y organizativas apropiadas, en la medida de lo posible, para que este pueda cumplir con su obligación de responder a las solicitudes de ejercicio de los derechos de los interesados (acceso, rectificación, supresión, oposición, limitación y portabilidad).

El MSP asiste al Responsable a garantizar el cumplimiento de las obligaciones de los artículos 32 a 36 RGPD, teniendo en cuenta la naturaleza del tratamiento y la información de que dispone el MSP. En particular, el MSP notifica al Responsable, sin dilación indebida y en todo caso dentro de las 24 horas, cualquier violación de la seguridad de los datos personales de que tenga conocimiento, con el contenido mínimo exigido por el art. 33.3 RGPD, sin perjuicio de la obligación general de notificación de incidentes de SGSI-DOC-006 §5, de la que esta es una concreción específica para datos personales.

8. Puesta a disposición de información y auditoría

El MSP pone a disposición del Responsable toda la información necesaria para demostrar el cumplimiento de las obligaciones de este anexo, y permite y contribuye a la realización de auditorías, incluidas inspecciones, por el Responsable o un tercero autorizado por este. Esta obligación se instrumenta, en la práctica operativa ya prevista en SGSI-DOC-006 §5, mediante el derecho de auditoría anual del nivel T1 y la verificación técnica independiente anual (pentest acotado a la superficie de la residencia y la oficina) cuyo resultado alimenta el registro de riesgos.

9. Destino de los datos a la finalización

A la finalización de la prestación de los servicios, el MSP, a elección del Responsable, suprime o devuelve todos los datos personales, y suprime las copias existentes, salvo que el Derecho de la Unión o de los Estados miembros exija la conservación de los datos personales. La supresión se acredita mediante el mismo procedimiento de borrado certificado de la sección 4.

10. Región de alojamiento y transferencias internacionales (art. 44 a 49 RGPD)

El MSP declara formalmente que la región de alojamiento del tenant de M365 contratado por el Responsable se encuentra dentro del Espacio Económico Europeo. Queda prohibida cualquier transferencia internacional de datos personales del Responsable fuera del EEE sin autorización previa y expresa por escrito de la Dirección General y sin las garantías del artículo 46 RGPD que en su caso correspondan. La declaración debe contrastarse con evidencia del proveedor antes de cerrar la verificación pendiente en el tratamiento T-10 (SGSI-REG-008).

11. Vigencia, modificación y ley aplicable

Este anexo entra en vigor en la fecha de su firma por ambas partes y se rige e interpreta conforme a la legislación española. Cualquier modificación se formaliza por escrito y con el mismo procedimiento de aprobación que este documento.

Anexo A. Trazabilidad

Sección	Control ISO/IEC 27001:2022 (Anexo A)
1 — Objeto, partes y duración	Art. 28.3 RGPD
2 — Naturaleza, finalidad y colectivos	Art. 28.3.a RGPD; SGSI-REG-008 T-10
3 — Instrucciones del Responsable	Art. 28.3.a y 29 RGPD; 5.9
4 — Medidas de seguridad	Art. 32 RGPD; 5.21, 5.22, 5.23, 7.10, 7.14, 8.2, 8.9, 8.15, 8.17, 8.22; SGSI-DOC-006 §5
5 — Personal y confidencialidad	Art. 28.3.b RGPD; 6.6
6 — Subencargados	Art. 28.2, 28.3.d y 28.4 RGPD; 5.21
7 — Asistencia con derechos de los interesados	Art. 28.3.e RGPD
7 — Asistencia arts. 32-36 y notificación de violaciones	Art. 28.3.f y 33.2 RGPD; 5.24, 5.26
8 — Puesta a disposición y auditoría	Art. 28.3.h RGPD; 5.22, 5.35
9 — Destino de los datos	Art. 28.3.g RGPD; 8.10, 7.14
10 — Región de alojamiento y transferencias	Art. 44 a 49 RGPD; 5.23